JOURNAL OF CYBERSECURITY

Journal of Cybersecurity, 2025, tyaf039
https://doi.org/10.1093/cybsec/tyaf039

Research Paper

Cyber vulnerabilities and technical regulation of China-made CCTV IoT surveillance cameras in Australia

Ausma Bernot [1,*], Muhammad Arif Khan [2], Khurram Shahzad [2], Mert Karakaya [3], Conor Healy [3]

[1]School of Criminology and Criminal Justice, Griffith University, Southport, QLD 4215, Australia
[2]School of Computing and Mathematics, Charles Sturt University, Wagga Wagga, NSW 2678, Australia
[3]IPVM, 3713 Linden St, Suite B, Bethlehem, PA 18020, United States

*Corresponding author. Building G6 Room 3.12, School of Criminology and Criminal Justice, Griffith University QLD 4215, Gold Coast, Australia. E-mail: a.bernot@griffith.edu.au

Received 4 July 2024; revised 29 April 2025; accepted 22 August 2025

Abstract

Internet of Things (IoT) devices used on a wide scale are currently underregulated in Australia. Installing IoT devices on private property can lead to data security issues if targeted. In key locations like government buildings, the risk of surveillance increases. This research article addresses the recent national security concerns regarding China-made IoT CCTVs in Australia that had few technical evaluations of the cameras before their removal. This two-stage interdisciplinary research article proceeds in the following steps: first, by using the Common Vulnerability Scoring System (CVSS) framework, we assess the vulnerabilities of three IoT CCTV providers—Hikvision, Dahua, and Avigilon—that have been installed on Commonwealth government buildings and, second, we evaluate those findings against Australia's existing IoT CCTV regulation frameworks. We detect vulnerabilities in all three systems, although there are no High or Critical vulnerabilities in Avigilon devices when compared to Hikvision and Dahua. We also find that the current Australian regulations simultaneously overlap and do not sufficiently cover the existing cyber-vulnerabilities. The overlapping security frameworks, guidelines, and regulations address organizational cyber-hygiene and environmental security. Technical cybersecurity frameworks, however, are currently available only for select Commonwealth Government agencies on demand and are classified, excluding guidance for industry actors and state governments. We conclude that unified and mandatory cybersecurity guidelines would benefit the clarity of IoT CCTV systems and support the consumer benefit.

Keywords: CCTV; cybersecurity; cyber-supply chain; cyber-vulnerabilities; IoT security; IoT regulation

Introduction

Deployed on a large scale, Internet of Things (IoT) devices are currently underregulated in Australia [1, 2] and internationally [3]. Researchers widely acknowledge the lack of standardization of IoT security [4] and limited adherence where standards are available [5]. Cook *et al*. [6] note that "an absence of IoT security standards contributes significantly to IoT device vulnerabilities, with several incidents highlighting significant flaws in data security." The lack of standards, the neglect of most manufacturers to implement security-by-design network protocols and the heterogeneity between different components provide attackers with a gateway to compromise IoT systems [7]. The use of IoT devices in individual homes can raise data security concerns when an individual or a specific area becomes a target. Hacked cameras in homes and offices can be used to obtain and sell child exploitation material and other videos, such as from gynecologists' offices and locker rooms [8]. When IoT CCTVs are placed in strategic locations, such as Commonwealth or state government buildings, the risk level that such a location would become a surveillance or hacking target is higher.

© The Author(s) 2025. Published by Oxford University Press. This is an Open Access article distributed under the terms of the Creative Commons Attribution License (https://creativecommons.org/licenses/by/4.0/), which permits unrestricted reuse, distribution, and reproduction in any medium, provided the original work is properly cited.

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

Due to underregulation, the adoption of imported IoT CCTV cameras has raised highly politicized debates not only in Australia but also internationally. In particular, China-made surveillance cameras have been removed from federal buildings in the USA, UK, and Australia [3], but not nationally in Canada or New Zealand. In March 2021, the US Federal Communications Commission included the two largest Chinese IoT CCTV providers Hikvision and Dahua in the Covered List, which bans new products from being imported or sold in the USA [9]. The Federal Communications Commission deemed the companies a "national security threat to the integrity of communications networks or the communications supply chain" due to the two companies deemed to be "owned or controlled by, or otherwise connected to, the government of a covered foreign country," naming the People's Republic of China [10].

An audit published in February 2023 by Australia's Shadow Cybersecurity Minister recently challenged these standards and regulatory frameworks. It showed that more than 900 Dahua and Hikvision surveillance cameras made in China were in use by Commonwealth agencies and deemed them an imminent threat to national security [11]. Despite high levels of media attention, the audit did not examine the CCTVs' cybersecurity settings, current technical standards, or the security implications of other IoT CCTVs fully or partially manufactured in China. This auditing event and the subsequent removal of Hikvision and Dahua CCTVs and replacement with largely Canada-headquartered Avigilon security systems left open questions regarding (1) cybersecurity evaluation of IoT CCTVs and (2) regulation and governance of IoT security systems in professional and consumer settings in Australia.

In most cases, no technical evaluations were published preceding these bans. It is possible that classified technical evaluations were carried out before the bans; if so, those were not made available to the public. For example, further additions to the US Federal Communications Commission's Covered List that covered Hikvision and Dahua statutorily rely on a specific determination of an entity posing "an unacceptable risk" by a US national security agency or an interagency body [10]. Again, such evaluations were not made available to the public. Additionally, consumers and enterprises who use the technologies banned due to national security concerns, do not have a clear pathway to understanding the actual threat to their audio–visual data that these CCTV IoT devices might pose. Lithuania's National Cybersecurity Centre is the only national government body, as identified by the authors at the time of writing, that has publicly released their cybersecurity evaluation of video surveillance cameras for household use [12]. These concerns point to the current issue of underregulation of IoT CCTVs [1, 2].

CCTV cameras that are frequently advertised on both Hikvision and Dahua's websites can be connected to the internet. Both companies have authorized dealers to sell their products in Australia and respond to public tenders. In 2021, using the Shodan IoT search engine independent researchers found there were over 60 000 surveillance camera networks from the two companies in Australia—over 41 000 from Hikvision and 18 000 from Dahua [13]. Shodan, however, underrepresents the number of devices that are on private networks, have strong authentication measures, experience limited internet connectivity, do not respond to Shodan's probes, or have minimal information exposure. Thus, the actual number of active cameras would be much larger. These findings suggest that the removal of 900 IoT CCTVs is fractional and a more comprehensive approach to cybersecurity is needed nationally.

Currently, there is a suite of Australian technical regulations and standards relevant to internet-connected CCTVs relevant to government security. The Australia and New Zealand technical standards developed by Standards Australia regulate all CCTVs present on the market [14]. Additionally, Australian government agencies must also comply with a separate suite of standards set forth by defense organizations, such as "the Essential Eight" developed by the Australian Signals Directorate in collaboration with the Australia Cybersecurity Centre [15]. However, the case of the removal of Chinese-made IoT CCTVs from Commonwealth buildings has revealed that clear regulatory gaps exist in Australia because the simple act of counting the number of China-made cameras has resulted in the removal and change of the security systems. Additionally, little security information was provided to Australian consumers purchasing IoT CCTVs for private use.

This article aims to bridge the gap between Australia's existing IoT security regulations pertinent to CCTVs and technical cyber vulnerabilities evaluation of three large IoT CCTV systems—two from China-based manufacturers Hikvision and Dahua and a comparison company Avigilon, a Canada-headquartered global company, that has replaced the former surveillance cameras on Commonwealth buildings in Australia.

Main contributions: the main contributions of the paper are as follows:

- Analysis of Dahua, Hikvision, and Avigilon IoT CCTV systems using the CVSS framework [16]. The cyber-vulnerability evaluations were conducted from Australia by remotely connecting to the CCTV system facility in the US.
- Comparison of high or critical base score vulnerabilities of Dahua, Hikvision, and Avigilon IoT CCTV systems.
- Evaluation of Australian cybersecurity frameworks and their suitability to respond to identified vulnerabilities.
- Identification of research and policy implications for IoT CCTV cybersecurity in Australia.

The paper proceeds in the following parts: first, we outline the research aims and approach. We then describe the CCTV cameras setup and analysis of the vulnerability frameworks and present a comparison of CCTV camera parameters for cybersecurity purposes. The next section reviews and evaluates Australia's IoT CCTV security regulations, and we then summarize the research and policy implications. The article concludes that recent Australia's Commonwealth Government decisions to transition Hikvision and Dahua security systems to Avigilon are consistent with the findings of the Common Vulnerability Scoring System (CVSS) vulnerability assessment framework. We also note the urgent need to create mandated security requirements for the consumer-facing IoT CCTV industry, as well as provide consumer resources for understanding IoT CCTV security risks.

Research aims and approach

In this project, we adopted a two-stage interdisciplinary research design that first completes a cybersecurity evaluation of three IoT CCTV system providers and, second, evaluates those findings against Australia's existing IoT CCTV regulation frameworks.

The first part of the manuscript evaluates data vulnerabilities related to the most popular cameras from Hikvision and Dahua. For comparison, we also review a camera manufacturer Avigilon. Avigilon was selected because it is now a widely deployed CCTV surveillance system on Australian Government buildings in Canberra, as evidenced by the first author's six site visits to Commonwealth sites listed in the February 2023 audit. The visits took place in September 2023. The cyber vulnerability evaluation followed the CVSS de-

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

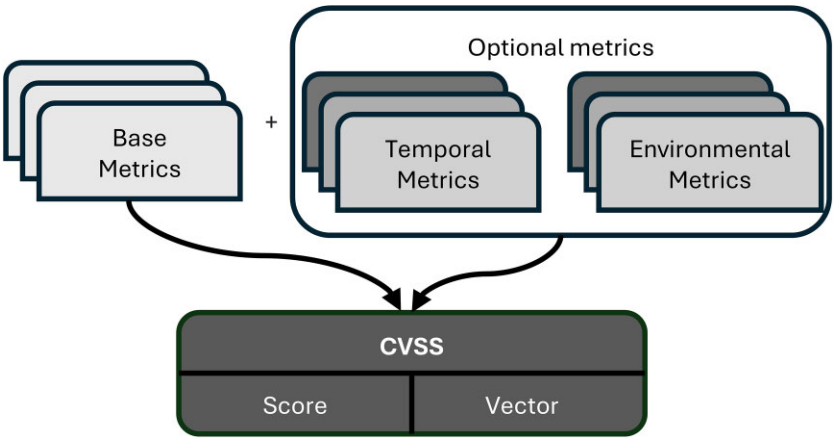


Figure 1. The CVSS framework metrics.

veloped and maintained by the National Institute of Standards and Technology. The methodology used is described in detail in the next section.

The second part of the manuscript compares the results of the first part with existing standards and technical regulations at the national level in Australia. We review all relevant Australia's standards and regulations pertinent to IoT CCTV security and compare the technical vulnerabilities found against the existing standards.

CCTV camera setup and analysis

In this section, we delve into the second phase of our methodology. We begin by exploring several frameworks commonly used for evaluating the vulnerabilities of IoT devices and CCTV cameras. Next, we describe the experimental setup employed in this research. Following that, we discuss the software tools utilized in the experiment. We then elaborate on the methods of information collection. Finally, we explain the penetration testing procedures used to launch cyber-attacks on the IoT CCTV cameras under investigation

Vulnerability assessment frameworks

Vulnerability assessments are an integral part of cyber risk management. They provide a systematic review and evaluation of security weaknesses in a system [17]. These assessment frameworks are valuable tools in identifying and highlighting specific cyber threats through various assessment scoring methods. Several frameworks exist for vulnerability scoring and some of them are listed below:

- CVSS [16] provides a way to capture the principal characteristics of a vulnerability and produce a numerical score reflecting its severity. The numerical scores help organizations properly assess and prioritize their vulnerability management processes.
- MITRE ATT&CK [18] is a curated knowledge base and model for cyber adversary behavior, reflecting the various phases of an adversary's attack lifecycle and the platforms they are known to target.
- Nessus [19] is a remote security scanning tool, that uses vulnerability scanners to automatically score vulnerabilities, according to the CVSS standard.
- Graph/tree-based [20, 21] frameworks are used to model how a system could be attacked, providing efficient ways to model scenarios and quantify security vulnerabilities, highlighting the paths an attacker could take to achieve their goals.
- Game theory-based frameworks [22, 23] facilitate theoretical analysis of various cyber-attacks and enable professionals to gain useful insights in designing countermeasure strategies.

The CVSS framework was selected because it has been widely applied in the field of vulnerability testing and has consistently been validated as a tool for vulnerability testing over several of its version iterations [24, 25]. It should be noted that compared to other frameworks, the CVSS is a measure of the severity of a potential attack, not a method of calculating risk. As show in Fig. 1 below, the CVSS score is composed of three sets of metrics—*Base*, *Temporal*, and *Environmental*—where each of these metrics has an underlying scoring component. Base metrics are representative characteristics of the vulnerability. They do not change over time and are not dependent on real-world exploitation or on mitigating factors that an organization has put into place to avoid any exploitation. As Commonwealth concerns driving the removal of China-made IoT CCTVs were threats to national security and the potential for foreign actors to exploit system vulnerabilities [26, 27], we consider that the CVSS is a viable framework to address these specific policy concerns. Temporal metrics encompass the aspects of a vulnerability that change over time and measure the current exploitability of the vulnerability, as well as the availability of any countermeasures such as patch or updates. Environmental metrics, on the other hand, allow an organization to modify the Base CVSS based on asset criticality and countermeasures that have been put into place, thus reflecting the impact of the vulnerability on a specific organization.

It is noted that the National Vulnerability Database [28] does not currently provide temporal and environmental scores for the reported vulnerabilities. However, actionable insights for technology deployment regarding vulnerability remediation priorities are easily achieved using the CVSS Base metrics scoring system. Taking into account the parameters related to a vulnerability including Attack Vector, Scope, Attack Complexity, Confidentiality, Privileges Required, Integrity, User Interaction, and Availability, the assessment score obtained from these principal characteristics can be translated into a qualitative representation. The higher the score based on the values awarded to these metrics, the more severe the vulnerability.

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

```
┌──(root㉿kali)-[/home/kali]
└─# nmap 192.168.1.116
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-01-16 22:28 EST
Nmap scan report for 20C-H6M-D1-IR-102205107239 (192.168.1.116)
Host is up (0.65s latency).
Not shown: 996 closed tcp ports (reset)
PORT    STATE SERVICE
80/tcp  open  http
443/tcp open  https
554/tcp open  rtsp
555/tcp open  dsf

Nmap done: 1 IP address (1 host up) scanned in 4.05 seconds
```

Figure 2. Nmap result for Avigilon WDR camera.

```
┌──(root㉿kali)-[/home/kali]
└─# nmap 192.168.1.162
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-01-16 22:22 EST
Nmap scan report for N35AJ52 (192.168.1.162)
Host is up (0.51s latency).
Not shown: 998 closed tcp ports (reset)
PORT    STATE SERVICE
80/tcp  open  http
554/tcp open  rtsp

Nmap done: 1 IP address (1 host up) scanned in 7.09 seconds
```

Figure 3. Nmap result for Dahua Starlight camera.

Experimental setup

Different experiments were conducted to evaluate the robustness, resilience, and prevention capabilities of three commonly used security cameras, including *Avigilon H6M WDR*, *Dahua N53AJ52 Outdoor Eyeball Starlight*, and *Hikvision DS-2CD2355FWD-I Turret Network*.

The network architecture used in these experiments relies on the use of *Wireguard* [29] to access the cameras deployed at IPVM offices in Bethlehem, Pennsylvania. The architecture also includes a computer running *Kali Linux* and a testing host. Kali Linux is run through *Oracle VM Virtualbox Manager 7.0* on a system running *Windows 10*, with i7-4790 CPU and 16 GB of RAM. The Kali Linux host is used to perform information gathering and launching attacks including Denial of Service (DoS) and man-in-the-middle (MITM), while the testing host allows to evaluate the performance of these cameras under different attacks.

Software tools

Several software and tools have been used in the experimental part of this work to assess the performance of cameras under observation and are detailed below:

- Kali Linux [30] is a well-known platform for various information security tasks, such as penetration testing, security research, computer forensics, and reverse engineering.
- Wireshark [31] is an open-source network packet analyzer used for troubleshooting, analysis, and protocol development. It provides captured packet data in greater detail and is also frequently used for educational purposes.
- Nmap is a network discovery tool, also known as network mapper, Nmap can discover hosts and services on a computer network by sending packets and analyzing the responses.
- Bettercap [32] is a sniffing and spoofing tool in network security, commonly used for MITM attacks.

Information collection

To test the open ports on the cameras, we searched through *Nmap* as shown through the command results in Figs 2–4. In all three cameras, the state of transmission control protocol (TCP) port 554 is open, hosting a service of real-time streaming protocol RTSP. RTSP [33] is a network protocol for multimedia streaming systems, used to facilitate the exchange of audio and video information across networks. While Dahua and Hikvision are running http service on port 80, Avigilon is hosting both http and https services on ports 80 and 443, respectively. Operating https through its ports makes Avigilon highly resistant to MITM attacks. Furthermore, another Nmap test with the option of [nmap -O < IP>] can provide more details about the cameras and their operating system. The outcome of these commands is shown in Figs 5–7 for Dahua, Hikvision, and Avigilon cameras.

Penetration testing

Penetration testing, or ethical hacking, is a compilation of procedures and processes that help in the identification, evaluation, and possible exploitation of device security a system or organization. Such exercises help identify any weak spots in a system's defenses, which attackers could take advantage of. The main objective of penetration testing in this article is to identify the flaws in a subject CCTV cam-

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

```
┌──(root㉿kali)-[/home/kali]
└─# nmap 192.168.1.172
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-01-24 20:11 EST
Nmap scan report for 192.168.1.172
Host is up (0.25s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
80/tcp   open  http
554/tcp  open  rtsp
8000/tcp open  http-alt

Nmap done: 1 IP address (1 host up) scanned in 3.59 seconds
```

Figure 4. Nmap result for Hikvision Turret camera.

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -O 192.168.1.116
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-01-
20 18:34 EST
Nmap scan report for 20C-H6M-D1-IR-102205107239 (192.1
68.1.116)
Host is up (0.25s latency).
Not shown: 996 closed tcp ports (reset)
PORT    STATE SERVICE
80/tcp  open  http
443/tcp open  https
554/tcp open  rtsp
555/tcp open  dsf
No exact OS matches for host (If you know what OS is r
unning on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.94SVN%E=4%D=1/20%OT=80%CT=1%CU=38137%PV=Y%
DS=2%DC=I%G=Y%TM=65AC
OS:58B2%P=x86_64-pc-linux-gnu)SEQ(SP=106%GCD=1%ISR=10E
%TI=Z%CI=Z%II=I%TS=U)
```

Figure 5. Nmap result for Avigilon WDR OS query.

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -O 192.168.1.162
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-01-1
8 05:52 EST
Nmap scan report for N35AJ52 (192.168.1.162)
Host is up (0.26s latency).
Not shown: 998 closed tcp ports (reset)
PORT    STATE SERVICE
80/tcp  open  http
554/tcp open  rtsp
Device type: general purpose
Running: Linux 2.6.X|3.X
OS CPE: cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linu
x_kernel:3
OS details: Linux 2.6.32 - 3.10
Network Distance: 2 hops

OS detection performed. Please report any incorrect res
ults at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.41 sec
onds
```

Figure 6. Nmap result for Dahua Starlight OS query.

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -O 192.168.1.172
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-01
-24 20:18 EST
Nmap scan report for 192.168.1.172
Host is up (0.25s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
80/tcp   open  http
554/tcp  open  rtsp
8000/tcp open  http-alt
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.2 - 3.16
Network Distance: 2 hops

OS detection performed. Please report any incorrect r
esults at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.03 s
econds
```

Figure 7. Nmap result for Hikvision Turret OS query.

```
┌──(root㉿kali)-[/home/kali]
└─# hping3  192.168.1.162 --flood -d 512
HPING 192.168.1.162 (WG-Shahzad 192.168.1.162): NO FLAGS are set, 40
headers + 512 data bytes
hping in flood mode, no replies will be shown
```

Figure 8. DoS attack execution on Dahua Starlight camera using hping3.

era and its management software and to diagnose how these vulnerabilities affect the system performance. We received permission from IPVM prior to beginning the penetration testing attacks.

DoS attacks

A DoS attack disrupts a device's functionality by overwhelming it with malicious traffic. These attacks aim to prevent legitimate users from accessing the service by flooding it with excessive requests. When these attacks are coordinated from multiple sources, they are known as Distributed Denial of Service attacks. Orchestrating a DoS attack on the cameras under examination was achieved by using *hping3* functionality of Kali Linux. hping3 can send custom packets and display target replies like ping does with ICMP packets. To check the cameras, we used hping3 in flood mode, which sends the packets as fast as possible and does not show the replies. We used a data size of 512 bytes in our experiments. An instance of this command being executed for Dahua camera is shown in Fig. 8.

The cameras tested were not able to respond to most ping tests received from the testing host since they became overwhelmed processing the flood attack traffic. It was also noted that the cameras stopped providing the video stream while under the DoS attack. Once the command was ceased, the cameras resumed operation and provided the live stream. Thus, this attack affected considerably the performance of the cameras. Figure 9 shows the CVSS score for DoS attack on the cameras under examination, which is classified as High, with a value of 7.5.

A similar attack can be launched using the hping3 tool with TCP SYN flood on a targeted port on the camera under examination. Here, TCP SYN packets initiating TCP connection requests are sent using spoofed source Internet Protocol (IP) addresses. Since the target camera will never receive ACK messages from the spoofed clients to completely establish the connections, causing it to get overwhelmed with the spoofed TCP traffic.

An instance of this command being executed at Dahua camera with a data size of 512 bytes is shown in Fig. 10.

MITM attack

A MITM attack is a general term for when an attacker puts themselves in a conversation between a user and an application (or another user) to either eavesdrop or to masquerade as one of the parties, making it appear as if a normal exchange of information is underway. The attacker secretly relays and can possibly alter the communications between the two parties who believe that they are communicating with each other directly. The communicating party's assumption that they are interacting with a trustworthy party may see them willingly provide sensitive information and compromising data. The MITM attacks are commonly achieved through poisoning the target user's ARP caches [34, 35] and thus redirecting the traffic exchange between target parties to the attacker, for sniffing or modification.

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

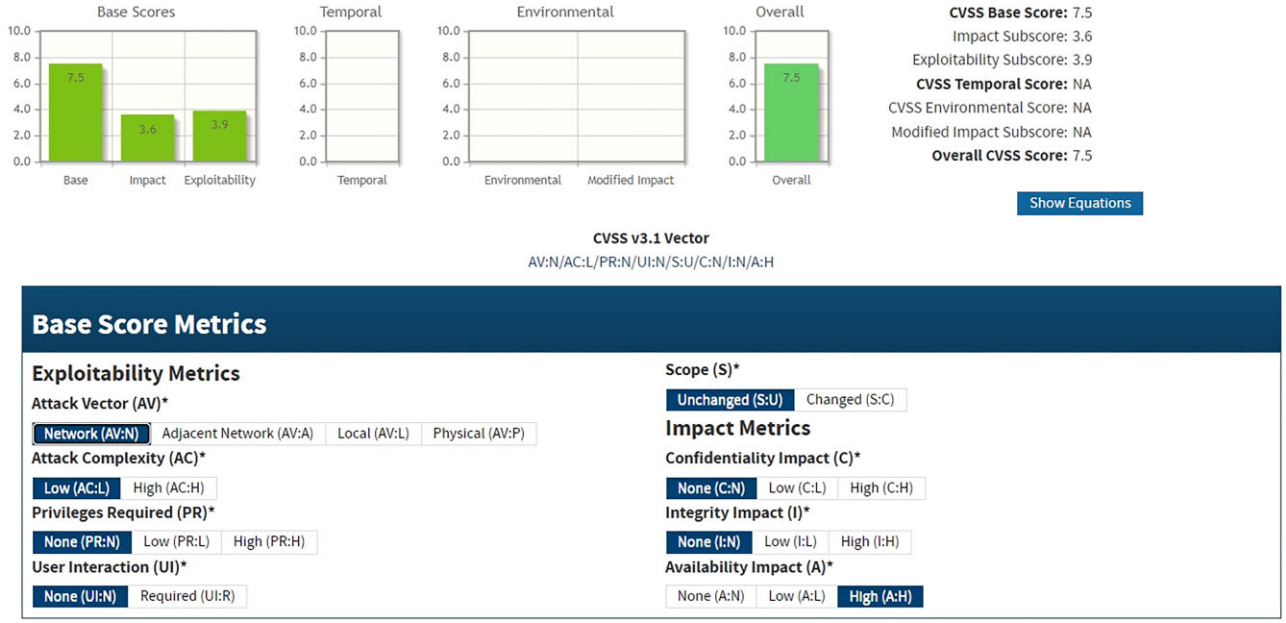


Figure 9. CVSS score for DoS attack.

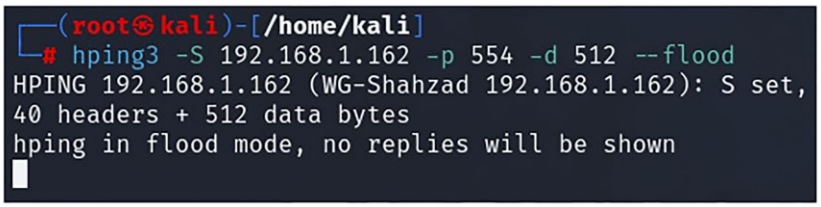


Figure 10. TCP SYN flood attack execution on Dahua Starlight camera using hping3.

The received packets are forwarded to the original users by the attacker, such that the original communication is not interrupted. The attacker node first enables its packet routing option so that it can act as a router and is able to forward rerouted packets to the originally communicating parties. Next, the attacker corrupts the ARP caches of the communicating parties using ARP poisoning techniques. The MITM attack can be simulated using simple tools with friendly user interfaces such as Bettercap in Kali Linux.

Local Area Network Denial attack

A Local Area Network Denial (LAND) attack is a type of DoS attack, where the attacker sets the source and destination information of a TCP segment to be the same. This is achieved using a specially crafted TCP Synchronize, or TCP SYN, packet such that the sender's IP address and TCP port are set to be the same as the destination IP address and port. Furthermore, the packet is sent to an open TCP port on the target system. When the target device tries to reply, it enters a loop, sending the packet for reprocessing in an infinite loop, which can eventually cause the target device to crash.

Comparison of camera parameters for cybersecurity

In 2023, IPVM Research published a report on the comparative analysis for IP cameras cybersecurity through various testing criteria. This analysis was based on various features associated with IP cameras and the details can be found on the IPVM website [36]. Table 1 below provides some of the key components of this analysis criteria for the cameras and list whether they are available/applicable in the cameras under consideration.

Based on the results of this testing, IPVM also provided rankings of IP camera cybersecurity [37], identifying significant differences between different manufacturers. As per IPVM's testing, Avigilon had above-average results in both Attack Surface categories and Fundamental Built-In Security Features. Avigilon also offers TPM security, though it is missing session timeout, but has HTTPS enabled by default, supports TLS v1.3 and effectively blocks access to resources on its web server without authentication. On the other hand, Dahua had above-average results in Fundamental Built-In Security Features. However, Dahua suffers from the TLS Secure Client-Initiated Renegotiation DoS vulnerability, lacks support for TLS v1.3 and has multiple discovery protocols enabled by default. Hikvision's Cloud/P2P IP Camera Connection had strong results, but the Hik-Connect app presented notable cybersecurity issues in communication with the Cloud. Hikvision does not offer TPM chip security, though it has brute force login locking and HTTPS enabled by default.

It is important to note the significance of firmware considerations for these cameras. While IPVM tested these cameras using the latest firmware versions, some of these cameras require tedious upgrade procedures where security managers need to use proprietary tools or access cameras one by one to upgrade firmware, typically in person.

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

Table 1. Comparative analysis for IP cameras cybersecurity through various testing criteria. Adopted from IPVM testing Table [36].

Features	Avigilon	Dahua	Hikvision
Built-in security features			
Trusted platform module	✓	✗	✗
Secure boot	✓	✓	✓
Signed firmware	✓	✓	✓
IP address filter	✓	✓	✓
MAC address filter	✗	✓	✓
Login lock	✓	✓	✓
Advanced built-in security features			
Control flow integrity	✗	✗	✗
Intrusion detection and prevention	✗	✗	✗
IEEE 802.1x	✓	✗	✓
Attack surface—WebUI and HTTPS			
Login challenge/response	✓	✓	✓
WebUI can be disabled	✓	✗	✗
Session timeout enabled	✗	✓	✓
Access without authentication	✗	✓	✓
HTTPS enabled	✓	✗	✓
Known TLS vulnerabilities not exist	✓	✗	✓
Attack surface—disabled services			
RTSP	✗	✗	✗
Onvif	✗	✗	✓
SNMP	✓	✓	✓
IP camera digital fingerprinting			
UPnP/SSDP discovery	✓	✗	✗
MDNS not exist/enabled	✓	✓	✓
PDP not exist/enabled	✓	✗	✗
Cloud/P2P IP camera connection			
UDP not used or is encrypted	✓	✗	✓
TCP not used or is encrypted	✓	✓	✓
Cloud exist and disabled	✗	✓	✓
Update/manufacturer support			
Firmware distribution not encrypted	✗	✗	✗
Cloud firmware check/update	✗	✓	✗
SSH and disabled	✗	✓	✓
Firmware/hardware support	✗	✗	✗

This process can delay/prevent systems from being up-to-date with their firmware, exposing them to vulnerabilities. Given the numerous identified vulnerabilities with Hikvision/Dahua cameras, they are more susceptible to attacks.

National Vulnerability Database reported vulnerabilities

The National Vulnerability Database (NVD) is the US government repository of standards-based vulnerability management data represented using the Security Content Automation Protocol [38]. This data enables automation of vulnerability management, security measurement, and compliance. The NVD includes databases of security checklist references, security-related software flaws, product names, and impact metrics. Vulnerabilities have been identified and reported to NVD in relation to Avigilon, Dahua, and Hikvision devices. In Tables 2 and 3, we list the vulnerabilities reported in recent years with a high or critical base score for Dahua and Hikvision devices, as per CVSS metrics. The results of running the Nmap vulnerability scans for these cameras are shown in Figs 11–13. We note that no high or critical base score vulnerabilities were reported for Avigilon devices in the NVD database.

The overview and evaluation of Australian IoT CCTV security frameworks

There are currently several overlaying binding and nonbinding standards, regulatory frameworks, and technical support resources related to IoT CCTVs in Australia. However, except for the video surveillance standards as well as IoT security standards set by Standards Australia, all of the other current regulations in Australia refer to the broad guidelines for organizational cyber hygiene. This section outlines the standards and regulations gathered from an extensive review of government documents. It reviews both binding and nonbinding IoT CCTV security standards and evaluates CVEs found in Hikvision, Dahua, and Avigilon systems against these standards.

Binding IoT CCTV security standards

The most important and stable binding standards are set by Australia's peak regulatory body—Standards Australia [14]. Standards Australia enforces the core binding standards as relevant to CCTVs and IoT, which are then enforced by the regulatory bodies in their relevant fields. Specifically, AS/NZS 62676.2.1:2020 focuses on video transmission protocols, while AS/NZS 62676.2.2:2020 delves into IP interoperability for internet-connected CCTVs, emphasizing implementation based on HTTP and REST services. Similarly, AS/NZS IEC 62676.2.31:2020 covers live streaming and control through web services and AS/NZS IEC 62676.2.32:2020 addresses recording control

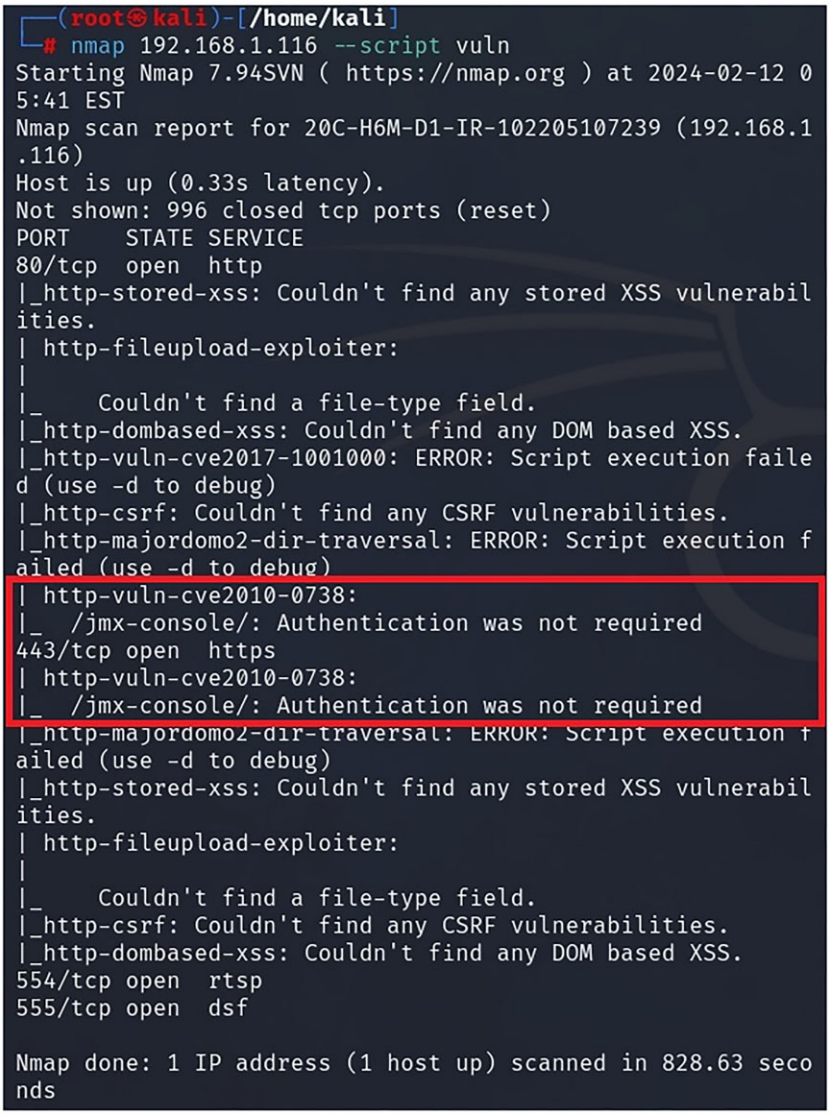
Table 2. Recent NVD dictionary entries for Dahua devices with a high or critical base score.

Dictionary entry	CVE name	Base score	Description
CVE-2022–45 423	Missing authentication for critical function	7.5	Unauthenticated request of MQTT credentials.
CVE-2022–45 431	Insufficient information	7.5	Unauthenticated restart of remote DSS server.
CVE-2022–45 429	Server-side request forgery	7.5	Access to internal resources using concatenating links (URL).
CVE-2022–45 427	Unrestricted upload of file with dangerous type	7.2	Upload arbitrary files by sending crafted packets to vulnerable interface.
CVE-2022–45 425	Use of hard-coded credentials	7.5	Obtain the AES crypto key by using hard-coded cryptographic key.
CVE-2021–33 046	Improper authentication	9.8	Exploitation through specific deployments to reset passwords in reset process.
CVE-2021–33 044	Improper authentication	9.8	Bypass device identity authentication by constructing malicious packets during the login process.

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

Table 3. Recent NVD dictionary entries for Hikvision devices with a high or critical base score.

Dictionary entry	CVE name	Base score	Description
CVE-2023–28 808	Insufficient information/improper access control	9.8	Access control vulnerability in Hikvision storage products that can be used to obtain admin permission.
CVE-2022–28 173	Improper access control	9.8	Access control vulnerability in Hikvision wireless bridge products that can be used to obtain admin permission.
CVE-2021–36 260	Improper neutralization of special elements used in OS command	9.8	Command injection vulnerability in Hikvision product web server that attacker can exploit to launch a command injection attack.
CVE-2018–6414	Improper restriction of operations within the bounds of a memory buffer	9.8	Buffer overflow vulnerability in web server of some Hikvision IP cameras allowing attacker an exploitation corrupting memory and arbitrary code execution



```
┌──(root㉿kali)-[/home/kali]
└─# nmap 192.168.1.116 --script vuln
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-12 0
5:41 EST
Nmap scan report for 20C-H6M-D1-IR-102205107239 (192.168.1
.116)
Host is up (0.33s latency).
Not shown: 996 closed tcp ports (reset)
PORT    STATE SERVICE
80/tcp  open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabil
ities.
| http-fileupload-exploiter:
|
|_    Couldn't find a file-type field.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-vuln-cve2017-1001000: ERROR: Script execution faile
d (use -d to debug)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-majordomo2-dir-traversal: ERROR: Script execution f
ailed (use -d to debug)
| http-vuln-cve2010-0738:
|_  /jmx-console/: Authentication was not required
443/tcp open  https
| http-vuln-cve2010-0738:
|_  /jmx-console/: Authentication was not required
|_http-majordomo2-dir-traversal: ERROR: Script execution f
ailed (use -d to debug)
|_http-stored-xss: Couldn't find any stored XSS vulnerabil
ities.
| http-fileupload-exploiter:
|
|_    Couldn't find a file-type field.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
554/tcp open  rtsp
555/tcp open  dsf

Nmap done: 1 IP address (1 host up) scanned in 828.63 seco
nds
```

Figure 11. Nmap vulnerability scan for Avigilon WDR camera.

and replay using web services. These standards establish a framework for the deployment and operation of video surveillance technologies, particularly IoT devices.

A small push toward more binding regulations has been made by Engineers Australia—a national body of engineering—to adopt several global IoT security standards. In their 2024 submission to the Australian Government on the "2023–2030 Australian Cybersecurity Strategy," Engineers Australia recommended two standards: (1) ETSI EN 303645, that is the European Standard for cybersecurity for consumer IoT devices, and (2) IEC 62443, that addresses technical and organizational security considerations in industrial automation and control systems throughout their lifecycle [39]. ETSI EN 303645

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

```
┌──(root㉿kali)-[/home/kali]
└─# nmap 192.168.1.162 --script vuln
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-12 0
6:01 EST
Nmap scan report for N35AJ52 (192.168.1.162)
Host is up (0.25s latency).
Not shown: 998 closed tcp ports (reset)
PORT    STATE SERVICE
80/tcp  open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabil
ities.
| http-fileupload-exploiter:
|
|_    Couldn't find a file-type field.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-aspnet-debug: ERROR: Script execution failed (use -
d to debug)
| http-enum:
|   /cgi-bin/mj_wwwusr: Majordomo2 Mailing List (401 Unaut
horized)
|   /cgi-bin/vcs: Mitel Audio and Web Conferencing (AWC) (
401 Unauthorized)
|   /cgi-bin/ffileman.cgi?: Ffileman Web File Manager (401
 Unauthorized)
|   /cgi-bin/ck/mimencode: ContentKeeper Web Appliance (40
1 Unauthorized)
|   /cgi-bin/masterCGI?: Alcatel-Lucent OmniPCX Enterprise
 (401 Unauthorized)
|   /cgi-bin/awstats.pl: AWStats (401 Unauthorized)
|   /cgi-bin/image/shikaku2.png: TeraStation PRO RAID 0/1/
5 Network Attached Storage (401 Unauthorized)
|   /cgi-bin/: Potentially interesting folder (401 Unautho
rized)
|_  /config/: Potentially interesting folder
554/tcp open  rtsp

Nmap done: 1 IP address (1 host up) scanned in 1248.21 sec
onds
```

Figure 12. Nmap vulnerability scan for Dahua Starlight camera.

was also further supported by the Office of Impact Analysis in December 2023 [40].

Nonbinding IoT CCTV security regulation

Australia has several overlapping security frameworks, guidelines, and regulations that address IoT CCTV security. These regulations primarily refer to organizational cyber hygiene and environmental security. This article did not find any regulations that would address the High and Critical CVEs identified in Hikvision and Dahua cameras, indicating that IoT CCTVs remain underregulated from a technical standpoint.

In the context of defense and national security, there are several overlapping standards. Namely, the Information Security Manual, released by the Australian Cybersecurity Centre in December 2023 [41], outlines security measures specific to information systems. Furthermore, the Australian Security and Intelligence Organization's T4 protective security offers ongoing advisory services to government clients, advising on the protection of personnel, information, and physical assets, including considerations for perimeter security, access control, CCTV, alarm systems, locks, and other door hardware [42]. The Protective Security Policy Framework, published by the Department of Home Affairs, provides a comprehensive framework for safeguarding government assets [43]. This framework places emphasis on governance, including security governance information security, personnel and physical security. Additionally, the Australian Signals Directorate recognizes the risk of malicious attacks against IoT devices and currently recommends 13 nonbinding security-by-design principles through the AS ETSI EN 303645 standard on cybersecurity for consumer IoT devices enacted in Australia in November 2023 [44]:

1) No duplicated default or weak passwords.
2) Implement a vulnerability disclosure policy.
3) Keep software securely updated.
4) Securely store credentials.
5) Ensure that personal data is protected.
6) Minimize exposed attack surfaces.
7) Ensure communication security.
8) Ensure software integrity.
9) Make systems resilient to outages.
10) Monitor system telemetry data.

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

```
┌──(root㉿kali)-[/home/kali]
└─# nmap 192.168.1.172 --script vuln
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-12 0
5:36 EST
Nmap scan report for 192.168.1.172
Host is up (0.25s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
80/tcp   open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-enum:
|_  //system.html: CMNC-200 IP Camera (401 Unauthorized)
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2007-6750
|       Slowloris tries to keep many connections to the ta
rget web server open and hold
|       them open as long as possible.  It accomplishes th
is by opening connections to
|       the target web server and sending a partial reques
t. By doing so, it starves
|       the http server's resources causing Denial Of Serv
ice.
|
|     Disclosure date: 2009-09-17
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE
-2007-6750
|_      http://ha.ckers.org/slowloris/
|_http-csrf: Couldn't find any CSRF vulnerabilities.
```

Figure 13. Nmap vulnerability scan for Hikvision Turret camera.

11) Make it easy for consumers to delete personal data.
12) Make installation and maintenance of devices easy.
13) Validate input data.

In 2020 September, the Australian Department of Home Affairs released the voluntary "Code of Practice: Securing the IoT for Consumers (Code of Practice)" [45]. Low compliance with this voluntary Code of Practice was noted 3 years after its release, especially among smaller IoT firms [40]. IoT Alliance Australia, which is an industry body, provides general guideline literature including case studies, guidelines and codes of practice [46].

Technical aspects of IoT CCTV cybersecurity are missing from all these documents that only refer to organizational cyber hygiene. While an important element of considering cybersecurity when interacting with internet-connected devices, these regulations do not tackle the Critical and High CVEs that can cause the most damage to an organization or a consumer if exploited.

Future-oriented policy making

In 2023, the Office of Impact Analysis began codesigning mandatory security standards and an industry-led voluntary cybersecurity labeling scheme for consumer-grade smart devices in December 2023 [40]. As a developing document, this set of standards aims to support whole-of-economy cybersecurity uplift. The document also acknowledges that the current regulatory system is complex and unclear and that voluntary regulations have a limited influence on industry. To address these issues, the Office of Impact Analysis offers to adopt the internationally recognized ETSI EN 303645, also suggested by Engineers Australia in their submission [39] and currently recommended by the Australian Signals Directorate [44]. Based on the evaluation of consumer research, the document further proposes a voluntary labeling scheme for consumer devices. A broader regulatory option to consider is the European Union's Cyber Resilience Act introduced in December 2024; the Cyber Resilience Act sets minimum standards for IoT device technical cybersecurity and its maintenance [46].

Our research identifies that this standard would not be sufficient to address High and Critical CVEs. However, we agree that mandating an industry-facing international standard of cybersecurity and translating it into an easy-to-understand consumer scheme would be beneficial. Although some technical standards are indeed adopted by Commonwealth Government agencies in a classified manner, other arms of the Government and individual consumers do not have current access to cybersecurity information. Findings from other countries similarly suggest that, without standardization requirements, consumers are provided little IoT security information by manufacturers [47]. The EU's new Cyber Resilience Act is the most advanced regulation that will cover IoT security and assign penalties for non-compliant manufacturers and distributors when it comes into effect in 2027 [46].

Findings: research and policy implications

Our two-phase research shows two key findings: the first relates to the cyber vulnerability evaluation of Hikvision, Dahua, and Avigilon

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

cameras and the second evaluates the IoT CCTV regulatory framework in Australia.

Research implications

First, we find that vulnerabilities are present in all Hikvision, Dahua, and Avigilon IoT CCTVs, with the Avigilon system being the only one that did not contain high or critical base score vulnerabilities. Of further concern is the history of Hikvision and Dahua IoT CCTV products building backdoors to their product to access cameras remotely [48, 49]. While these backdoors have been "patched" with upgraded firmware, precedence shows the propensity of these two companies to build in nonsecure elements in their products. IoT CCTV systems are rarely built with automatic or even remotely performed updates, meaning that even when patches are released, they may not be applied very quickly, if at all. For example, in the early 2022, CYFIRMA estimated that over 80 000 devices worldwide were still vulnerable to Hikvision's backdoor logged as a CVE in 2021 [50]. The findings are in line with the CCTV replacement choices that have been implemented by Australian Commonwealth Government agencies, although no public cybersecurity evaluation of those cameras was released. Further research should compare the different vulnerability frameworks to the mandated security criteria currently proposed by the Office of Impact Analysis.

Postinstallation cyber vulnerability monitoring as Australia does not currently mandate/recommend vulnerability reporting and periodic security checks. Such monitoring and evaluation are currently only done by private actors, such as IPVM. The authors note that internal and classified technical guidelines do exist, but they are not publicly available to state governments or consumers more broadly. Additionally, the security-by-design principles for IoT CCTV manufacturers are also only developing at the time of writing. These two issues point to existing policy gaps, discussed in detail in the next section. As the Australian Government is moving to consider technical standards and mandatory standards as part of the 2023–2030 Australian Cybersecurity Strategy, research should thoroughly evaluate the suitability of the proposed AS ETSI EN 303645 and IEC 62443 standards along with other regulatory options [39].

It is worth noting that IoT CCTV security is temporal as new modes of attack emerge and will require periodic retesting. The CVSS framework is suitable to run such tests as it regularly updates existing and emergent cyber vulnerability lists. The limitation of this research is that it has only conducted a vulnerability-specific comparison between the existing IoT CCTV systems of Hikvision, Dahua and Avigilon to study an existing policy concern. A larger list of vulnerabilities across several IoT CCTVs available on the Australian market would be pertinent to examine for a more comprehensive overview.

Technical cybersecurity guidelines are currently lacking in Australia. Future research and policy making should consider how technical vulnerability testing could be incorporated into IoT CCTV governance at the levels of government and consumers. Our article provides one possible example. We recommend there should be a focus on mandating supplier compliance.

Policy implications

This research has found that IoT CCTVs in Australia are simultaneously overregulated in terms of the varied guidelines regarding organizational cyber hygiene and underregulated in terms of technical security standards. Additionally, non-Commonwealth government arms and individual consumers receive little guidance and support in choosing IoT CCTV systems.

At a broader level of national and international governance, negative regulatory actions that do not convert into organizational learning, such as the banning of specific devices, can only generate temporary and short-term regulatory solutions. Such approaches are not sustainable for bolstering national and international cybersecurity strategy in the long term, nor helpful in supporting consumers in evaluating their IoT CCTV options on the market. Mandatory regulations should not only include the broad principles of organizational cyber hygiene, but also clear technical standards for security-by-design implementation.

Further policy implications of our research contribute to the regulatory idea that more specific requirements should be directed at supplier governance. As the Office of Impact Analysis has identified, mandatory international security standards would provide the strongest impetus for the industry actors to comply [40]. We agree with the suggestion of the Office of Impact Analysis that internationally recognized mandatory standards would be a strong first step towards stronger cybersecurity of IoT CCTVs [40], including the ETSI EN 303645 European Standard for cybersecurity for consumer IoT devices and the IEC 62443 series of standards for maintaining electronically secure industrial automation and control systems. Additionally, in reviewing software security, Australia can leverage international strategic alliances to put in place economic incentives in mandating supplier compliance with core cybersecurity requirements, such as self-attesting or third-party certifying compliance with secure development practices or self-reporting product vulnerabilities to a national vulnerability disclosure program [51].

Aside from professional IoT CCTV applications that have a larger number of security evaluation resources, more questions remain for consumers choosing a CCTV for personal security. While security standards are implemented for video surveillance, IoT security standards are currently only suggested as a code of practice. This is the immediate regulatory change that should be implemented to protect individual consumers from IoT CCTV breaches. An annual easy-to-understand resource freely accessible to consumers on the most and least secure IoT CCTVs available in the market would also reduce the burden on individuals and motivate manufacturers to comply with nonbindings codes of practice. Further research could consider building a ranking system that would allow Australian consumers to make more informed decisions regarding their choice of IoT CCTVs. Such a ranking system could take the form of periodic IoT CCTV cybersecurity rankings (see, for example, IPVM CCTV rankings [37]). A star-based ranking system [52, 53] and voluntary labeling approach [54] for IoT security have also been suggested by cybersecurity scholarship and government policy research documents.

Conclusion

This interdisciplinary article first conducted comparative vulnerability testing of Hikvision, Dahua, and Avigilon IoT CCTV systems and, second, compared the outcomes of the vulnerability testing against the existing Australia's standards. The CVSS framework testing found existing vulnerabilities in all three systems, although no high or critical vulnerabilities were found among Avigilon devices as compared with Hikvision and Dahua systems. This suggests that the apparent change of IoT CCTVs from Hikvision and Dahua to Avigilon on Australian Commonwealth buildings was the correct change to enhance the security of IoT CCTVs. The authors suggest that CVSS testing, which updates emerging cyber vulnerabilities, can help manufacturers test and update their security protocols.

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

We also find that the current Australian regulations simultaneously overlap each other in considering organizational cyber hygiene but do not, however, include technical standards that would sufficiently cover the existing cyber vulnerabilities. Limited advice is available via the Australian Security and Intelligence Organization's T4 protective security program that is made available to state and territory governments, business enterprises, and critical infrastructure owners that can demonstrate supporting a Commonwealth interest [42].

We recommend that further guidelines should address this gap in two ways: (1) by encouraging IoT CCTV manufacturers in releasing secure products into the market through an adoption of mandatory technical international standards and (2) support the Australian Government agencies with unified technical guidelines for evaluating cybersecurity of IoT security systems, in addition to the currently available organizational cyber hygiene advice. The Commonwealth Government's Australian Cybersecurity Strategy is strongly committed to establishing alternative solutions in the event that voluntary regulations are insufficient, and it should take into account the conclusions of this research.

Acknowledgment

The authors of this paper would like to thank IPVM for granting remote access to their internet-connected devices for the purposes of this research.

Author contributions

Ausma Bernot (Conceptualization [equal], Data curation [equal], Formal analysis [equal], Funding acquisition [equal], Methodology [equal], Project administration [equal], Resources [equal], Supervision [equal], Writing - original draft [equal], Writing - review & editing [equal]), M. Arif Khan (Conceptualization [equal], Funding acquisition [equal], Methodology [equal], Supervision [equal]), Khurram Shahzad (Investigation [equal], Methodology [equal], Writing - original draft [equal], Writing - review & editing [equal]), Mert Karakaya (Data curation [equal], Investigation [equal], Methodology [equal]), and Conor Healy (Data curation [equal], Funding acquisition [equal], Writing - review & editing [equal])

Conflict of interest: None declared. In-kind support was provided by IPVM for access to testing facilities, which is acknowledged in the manuscript.

Funding

This research was funded by the Artificial Intelligence and Cyber Futures Center, Charles Sturt University.

References

1. Harkin D, Mann M, Warren I. Consumer IoT and its under- regulation: findings from an Australian study. *Pol Internet* 2022;**14**:96–113. https://doi.org/10.1002/poi3.285
2. Brown A, Harkin D, Tanczer LM. Considering the 'Internet of Things' for victim-survivors of domestic and family violence: anticipating exploitative use and encouraging safety-by-design. *Viol Against Wom* 2024;**31**:1039–62. https://doi.org/10.1177/10778012231222486
3. Smith M, Bernot A. Understanding the risks of China-made CCTV surveillance cameras in Australia. *Austr J Int Aff* 2023;**77**:380–98. https://doi.org/10.1080/10357718.2023.2248915
4. Karie NM, Sahri NM, Yang W. *et al.* A review of security standards and frameworks for IoT-based smart environments. *IEEE Access* 2021;**9**:121975–95. https://doi.org/10.1109/ACCESS.2021.3109886
5. Gebremichael T, Ledwaba LPI, Eldefrawy MH. *et al.* Security and privacy in the industrial internet of things: current standards and future challenges. *IEEE Access* 2020;**8**:152351–66. https://doi.org/10.1109/ACCESS.2020.3016937
6. Cook J, Rehman SU. Security and privacy for low power IoT devices on 5G and beyond networks: challenges and future directions. *IEEE Access* 2023;**11**:39295–317. https://doi.org/10.1109/ACCESS.2023.3268064
7. Cirne A, Sousa PR, Resende JS, Antunes L. IoT security certifications: challenges and potential approaches. *Comput Secur* 2022;**116**:102669. https://doi.org/10.1016/j.cose.2022.102669
8. IPVM. Child pornography on sale from hacked Hikvision cameras using current Hik-Connect app. 2023. https://ipvm.com/reports/cp-sale-hack (10 July 2023, date last accessed).
9. Federal Communication Commission. List of equipment and services covered by Section 2 of the Secure Networks Act. Washington, 2024. https://www.fcc.gov/supplychain/coveredlist (4 July 2024, date last accessed).
10. Federal Communications Commission. Implementing the Secure Networks Act, Declaratory Ruling. Washington, 2024. https://www.fcc.gov/document/implementing-secure-networks-act-0 (4 July 2024, date last accessed).
11. Senator James Paterson website. Audit: Commonwealth Riddled by CCP Spyware. 2023. https://archive.md/7k1fP (9 February 2023, date last accessed).
12. National Cyber Security Centre. Cyber Security Incident Analysis and Reports. London, 2024. https://www.nksc.lt/en/ (4 July 2024, date last accessed).
13. Hikvision and Dahua surveillance cameras. Global locations report. 2021. https://www.top10vpn.com/research/hikvision-dahua-surveillance-cameras-global-locations/ (16 November 2021, date last accessed).
14. Standards Australia. https://www.standards.org.au/ (4 July 2024, data last accessed).
15. Australian Cyber Security Centre. 2023. Essential Eight. Canberra. https://www.cyber.gov.au/resources-business-and-government/essential-cybersecurity/essential-eight (4 July 2024, data last accessed).
16. Forum of Incident Response and Security Teams. CVSS—Common Vulnerability Scoring System. https://www.first.org/cvss/ (4 July 2024, date last accessed).
17. Baho SA, Abawajy J. Analysis of consumer IoT device vulnerability quantification frameworks. *Electronics* 2023;**12**:1176. https://doi.org/10.3390/electronics12051176
18. Strom BE, Applebaum A, Miller DP. *et al.* Mitre ATT&CK: Design and Philosophy. Technical report. Bedford: The MITRE Corporation, 2018.
19. T. N. Security—Nessus. 2024. https://www.tenable.com/products/nessus (4 July 2024, date last accessed).
20. George G, Thampi SM. A graph-based security framework for securing industrial IoT networks from vulnerability exploitations. *IEEE Access* 2018;**6**:43586–601. https://doi.org/10.1109/ACCESS.2018.2863244
21. Wang H, Chen Z, Zhao J. *et al.* A vulnerability assessment method in industrial internet of things based on attack graph and maximum flow. *IEEE Access* 2018;**6**:8599–609. https://doi.org/10.1109/ACCESS.2018.2805690
22. George G, Thampi SM. Vulnerability-based risk assessment and mitigation strategies for edge devices in the Internet of Things. *Pervas Mob Comput* 2019;**59**:101068. https://doi.org/10.1016/j.pmcj.2019.101068
23. He Q, Wang C, Cui G. *et al.* A game-theoretical approach for mitigating edge DDoS attack. *IEEE Trans Depend Secure Comput* 2021;**19**:2333–48. https://doi.org/10.1109/TDSC.2021.3055559
24. Figueroa-Lorenzo S, Añorga J, Arrizabalaga S. A survey of IIoT protocols: a measure of vulnerability risk analysis based on CVSS. *ACM Comput Surv* 2020;**53**:1–53. https://doi.org/10.1145/3381038
25. Gallon L. Vulnerability discrimination using CVSS framework. In: *Proceedings of the 2011 4th IFIP International Conference on New Technologies, Mobility and Security*. Piscataway, NJ: IEEE, 2011, 1–6.
26. The Guardian. Chinese-made security cameras to be removed from Australian government buildings. 2023. https://www.theguardian.com/australia-news/2023/feb/09/chinese-made-security-cameras-to-be-removed-from-australia-government-buildings (9 February 2023, date last accessed).

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

27. BBC. Australia to remove Chinese surveillance cameras amid security fears. 2023. https://www.bbc.com/news/world-australia-64577641 (9 February 2023, date last accessed).
28. National Vulnerability Database. https://nvd.nist.gov/ (4 July 2024, date last accessed).
29. Donenfeld JA. Wireguard: next generation kernel network tunnel. In: *Proceedings of the Network and Distributed System Security Symposium, NDSS 2017*. San Diego, CA:Internet Society. 2017, 1–12. https://dx.doi.org/10.14722/ndss.2017.23160
30. Kali Linux. 2024. https://www.kali.org/docs/ (4 July 2024, date last accessed).
31. Wireshark. 2024. https://www.wireshark.org/ (4 July 2024, date last accessed).
32. Bettercap. 2024. https://www.bettercap.org/ (4 July 2024, date last accessed).
33. Real time streaming protocol (RTSP). 2024. https://www.cs.columbia.edu/hgs/rtsp/draft/draft-ietf-mmusic-rtsp-03.html (4 July 2024, date last accessed).
34. Doughty T, Israr N, Adeel U. Vulnerability analysis of IP cameras using ARP poisoning. In: *Proceedings of the 8th International Conference on Soft Computing, Artificial Intelligence and Applications (SAI 2019)*. Chennai, TN: AIRCC, 2019, 163–72.
35. Olazabal AA, Kaur J, Yeboah-Ofori A. Deploying man-in-the-middle attack on IoT devices connected to long range wide area networks (LoRaWAN). In: *Proceedings of the 2022 IEEE International Smart Cities Conference (ISC2)*. Piscataway, NJ: IEEE, 2022, 1–7.
36. Internet Protocol Video Market. Criteria for IP camera cybersecurity shootout explained. 2024. https://ipvm.com/reports/cam-cyb-criteria (4 July 2024, date last accessed).
37. Internet Protocol Video Market. IP Camera cybersecurity rankings. 2024. https://ipvm.com/reports/cam-cyber-rank-23 (4 July 2024, date last accessed).
38. National Institute of Standards and Technology. NVD Database. https://nvd.nist.gov/ (4 July 2024, date last accessed).
39. Engineers Australia. 2023-2030 Australian Cybersecurity Strategy: legislative reforms; Engineers Australia's submission. 2024. https://www.engineersaustralia.org.au/sites/default/files/2024-03/Engineers-Australia-Submission-2023-2030-Australian-Cyber-Security-Strategy-Legislative-Reforms.pdf (4 July 2024, date last accessed).
40. Office of the National Cyber Security Adviser. Mandatory security standards and industry-led voluntary cyber. 2023. https://oia.pmc.gov.au/published-impact-analyses-and-reports/mandatory-security-standards-and-industry-led-voluntary-cyber (11 December 2023, date last accessed).
41. Australian Government Information Security Manual. 2024. https://www.cyber.gov.au/resources-business-and-government/essential-cyber-security/ism (4 July 2024, date last accessed).
42. Australian Security Intelligence Organisation. ASIO T4 protective security. 2024. https://www.asio.gov.au/asio-t4-protective-security (4 July 2024, date last accessed).
43. Protective Security Policy Framework. 2024. https://www.protectivesecurity.gov.au/about#:~:text=The%20Protective%20Security%20Policy%20Framework,security%20governance (4 July 2024, date last accessed).
44. Australian Signals Directorate. IoT secure-by-design guidance for manufacturers. 2024. https://www.cyber.gov.au/resources-business-and-government/maintaining-devices-and-systems/system-hardening-and-administration/system-hardening/iot-secure-design-guidance-manufacturers (4 July 2024, date last accessed).
45. Home Affairs. Voluntary Code of Practice. 2025. https://www.homeaffairs.gov.au/reports-and-publications/submissions-and-discussion-papers/code-of-practice (4 July 2024, date last accessed).
46. European Commission. Cyber Resilience Act. 2024. Cyber Resilience Act. https://digital-strategy.ec.europa.eu/en/policies/cyber-resilience-act (4 July 2024, date last accessed).
47. Blythe JM, Sombatruang N, Johnson SD. What security features and crime prevention advice is communicated in consumer IoT device manuals and support pages? *J Cybersecur* 2019;5:1–10. https://doi.org/10.1093/cybsec/tyz005
48. IPVM. Dahua backdoor uncovered. 2017. https://ipvm.com/reports/dahua-backdoor (7 March 2017, date last accessed).
49. IPVM. Hikvision backdoor exploit. 2017. https://ipvm.com/reports/hik-exploit (4 September 2017, date last accessed).
50. CYFIRMA. News Coverage from Security Affairs: Over 80,000 Hikvision cameras can be easily hacked. 2024. https://www.cyfirma.com/news/news-coverage-from-security-affairs-over-80000-hikvision-cameras-can-be-easily-hacked/ (24 August 2022, date last accessed).
51. Banasiński C, Rojszczak M. Cybersecurity of consumer products against the background of the EU model of cyberspace protection. *J Cybersecur* 2021;7:1–15.
52. Rae A, Patel A. Defining a new composite cybersecurity rating scheme for SMEs in the U.K. In: Heng SH, Lopez J (eds), *Information Security Practice and Experience*. Cham: Springer International Publishing; 2019, 362–80.
53. Loi F, Sivanathan A, Gharakheili HH. *et al.* Systematically evaluating security and privacy for consumer IoT devices. In *Proceedings of the 2017 Workshop on Internet of Things Security and Privacy*. New York, NY: ACM, 2017, 1–6.
54. DLA Piper. FCC to consider implementing a voluntary cybersecurity labeling program for smart products. 2024. https://www.dlapiper.com/en/insights/publications/2024/02/fcc-to-consider-implementing-a-voluntary-cybersecurity-labeling (29 February 2024, date last accessed).

Downloaded from https://academic.oup.com/cybersecurity/article/11/1/tyaf039/8345066 by guest on 10 March 2026

© The Author(s) 2025. Published by Oxford University Press. This is an Open Access article distributed under the terms of the Creative Commons Attribution License (https://creativecommons.org/licenses/by/4.0/), which permits unrestricted reuse, distribution, and reproduction in any medium, provided the original work is properly cited.